

Esercizio 5: Anyrun

Studiare questi link di **anyrun** e spiegare queste minacce in un piccolo report.

<https://app.any.run/tasks/371957e1-d960-4b8a-8c68-241ff918517d/>

<https://app.any.run/tasks/f1f20828-2222-46fb-a886-09f77581e67b/>

Come output vorrei la spiegazione in italiano per un eventuale cliente / manager (che è poco preparato sulla materia) di questi malware (o presunti tali). Indicare le vostre scelte di remediation (mettere in quarantena, eliminare, blacklist, falso positivo, falso negativo, vero positivo, vero negativo, chiedo al vendor, ecc.) motivandole.



Minaccia1: Malware "Infostealer" (Agent Tesla)

- **Fonte:** <https://app.any.run/tasks/371957e1-d960-4b8a-8c68-241ff918517d/>

Questa minaccia è un malware, ovvero un software malevolo che si installa sul computer della vittima. Nello specifico, si tratta di un tipo chiamato "Info-stealer" (ladro di informazioni).

Si può immaginare come una spia digitale che lavora in segreto per rubare ogni tipo di dato sensibile, come:

- **Password salvate nei browser web** (es. Chrome, Firefox).
- **Credenziali** dei programmi di posta elettronica (es. Outlook).
- Tutto ciò che viene digitato sulla tastiera, inclusi messaggi privati o dati bancari.
- **Screenshot** dello schermo.

Il pericolo è molto elevato, poiché le informazioni rubate possono essere usate per furti finanziari, accessi **non autorizzati** alla rete aziendale o altre attività criminali.



Dettagli Tecnici dell'Analisi

Dall'analisi di any.run sono emersi i seguenti dettagli tecnici:

File Iniziale: L'infezione parte da un eseguibile identificato come **vidar.exe** (hash: 66bddf8b...).

Catena di Esecuzione e Tecniche di Evasione:

- Il malware non opera direttamente, ma utilizza una tecnica di "**mascheramento**" per evadere le difese, nota come Process Hollowing o Injection.
- Crea dei processi usando un'utility legittima di Windows, RegAsm.exe. Questo gli permette di **eseguire** codice **malevolo** sotto le mentite spoglie di un processo di sistema affidabile, ingannando gli antivirus più semplici.
- I processi malevoli con nomi casuali (es. HCAEHJJKFC.exe, CAFHDBGHJK.exe) vengono eseguiti e a loro volta lanciano queste istanze **mascherate** di RegAsm.exe.

Doppio Payload Rilevato: Le firme di sicurezza (regole YARA e Suricata) hanno rilevato in modo inequivocabile la presenza di **due famiglie di malware distinte**:

1. **Vidar:** Un noto e potente Infostealer.
2. **Lumma:** Un altro Infostealer, probabilmente scaricato come payload secondario. Questo indica un possibile modello di business criminale (Malware-as-a-Service) in cui un'infezione viene "venduta" o usata per distribuire altre minacce.

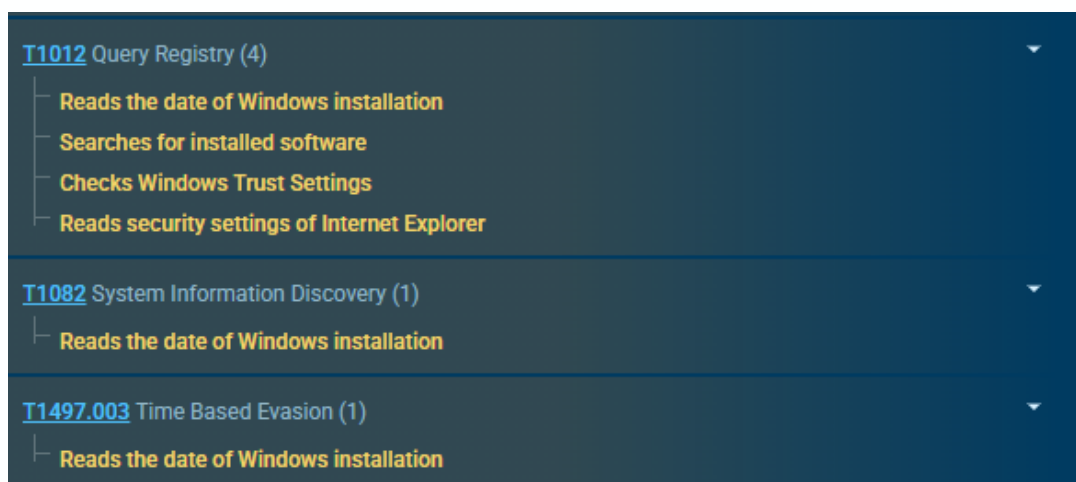


Azioni Malevole Osservate (Tattiche MITRE ATT&CK):

- **Furto Credenziali (T1555, T1552):** Il malware ha tentato attivamente di estrarre password salvate nei browser web e in file locali.
- **Raccolta Informazioni (T1082, T1012, T1518):** Ha eseguito una scansione del sistema per identificare software installato, configurazioni di sicurezza e altre informazioni utili per l'attaccante.
- **Auto-Cancellazione:** L'uso del comando `cmd.exe /c timeout /t 10 & rd /s /q "C:\ProgramData\..."` mostra che il malware tenta di cancellare le proprie tracce dopo aver completato il furto di dati.



- **T1012 Query Registry** (Interrogazione del Registro):
 - Cerca il software installato per identificare tool di sicurezza.
 - Controlla le impostazioni di fiducia di Windows e Internet Explorer per trovare e sfruttare configurazioni deboli.
- **T1082 System Information Discovery** (Scoperta Informazioni di Sistema):
 - Legge la data di installazione di Windows per raccogliere dati da inviare al server C2 (Comando e Controllo).
- **T1497.003 Time Based Evasion** (Evasione Basata sul Tempo):
 - Controlla l'età dell'installazione di Windows. Se il sistema è troppo "giovane" (tipico di una sandbox o VM), il malware conclude di essere analizzato e si ferma o si nasconde per evitare di rivelare il suo payload completo





Scelta di Remediation

Analisi: **Vero Positivo**. Si tratta di un file inequivocabilmente dannoso.

1. Azione Consigliata: Soluzione Domestica

- Motivazione: Se il malware è in una fase minore della sua espansione nel proprio dispositivo, è anche utilizzabile un antivirus di uso domestico per la rimozione del malware

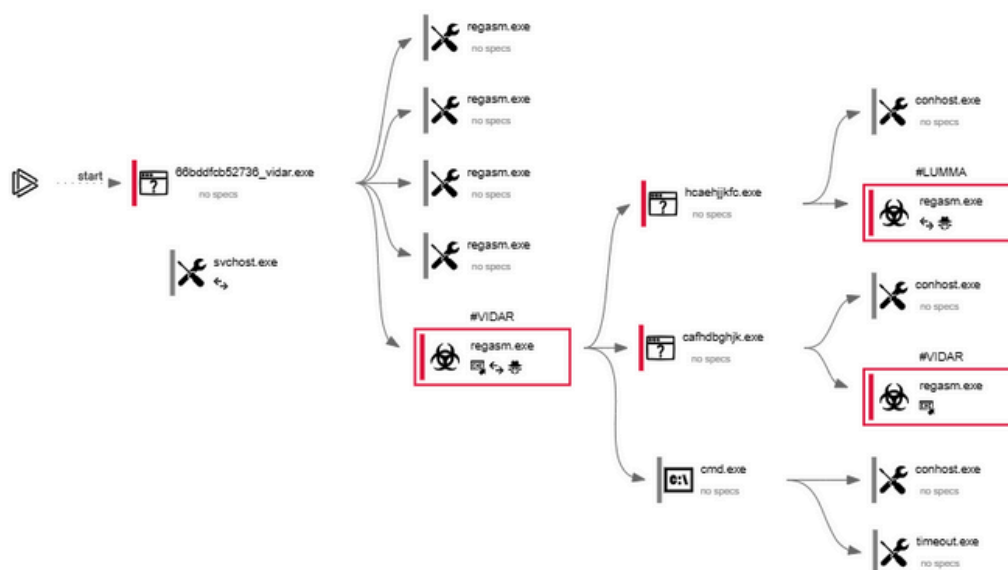
1. Azione Consigliata: Soluzione aziendale

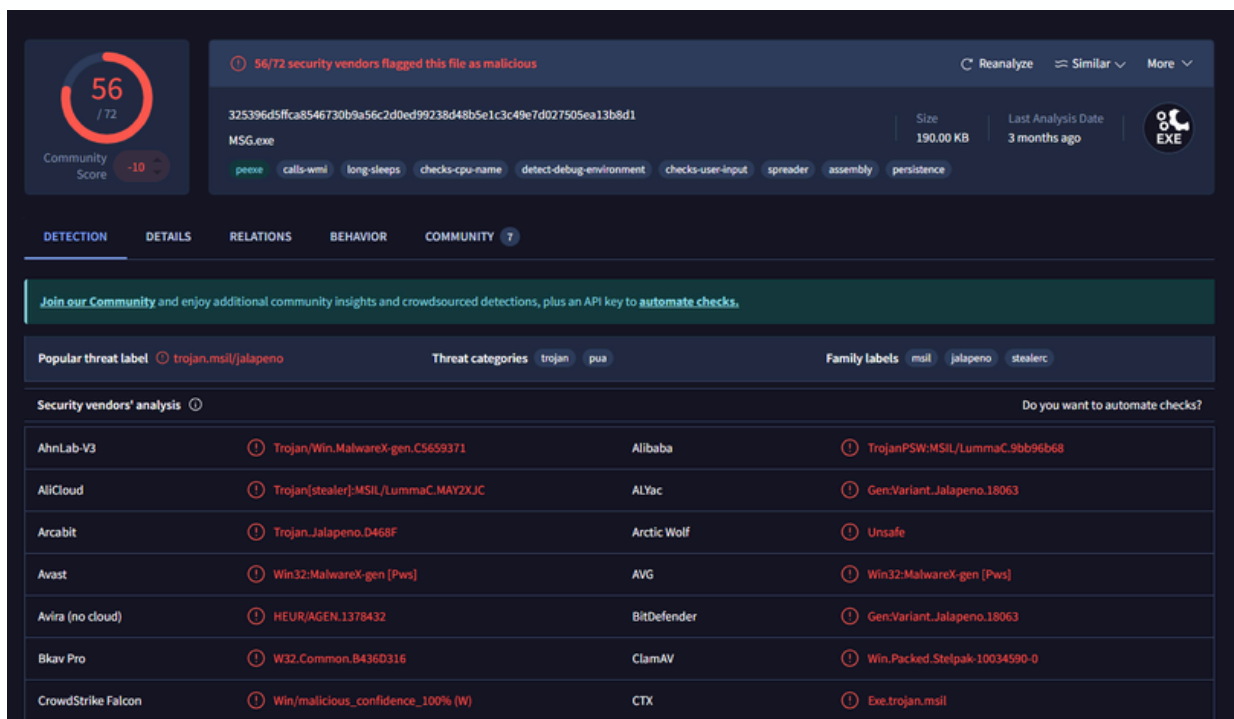
- Motivazione: Se il malware si trova in una fase avanzata data la sua capacità di nascondersi e rubare dati, può essere sufficiente una soluzione enterprise (edr, ngfw, soar) che garantisce una rimediazione.

1. Azione Consigliata: Soluzione Nucleare

- Motivazione: Se non fosse sufficiente mettere in quarantena questo malware. È necessario isolare immediatamente il computer infetto dalla rete per evitare che la minaccia si diffonda, procedere con la sua eliminazione completa (idealmente, tramite una reinstallazione del sistema) e, infine, inserire in blacklist (la "lista nera" aziendale) sia la sua "impronta digitale" (hash) sia tutti gli indirizzi internet a cui ha tentato di connettersi.

*ATTENZIONE: Se i dati sono esfiltrati, non c'è rimedio per recuperare i dati





The screenshot shows the VirusShare analysis interface for a file named MSG.exe. At the top, a circular gauge indicates a Community Score of 56 out of 72. A notification states that 56/72 security vendors flagged the file as malicious. The file's SHA-256 hash is 325396d5ffca8546730b9a56c2d0ed99238d48b5e1c3c49e7d027505ea13b8d1. The file size is 190.00 KB, and the last analysis date was 3 months ago. Below this, a list of behaviors is shown: peexe, calls-wmi, long-sleeps, checks-cpu-name, detect-debug-environment, checks-user-input, spreader, assembly, and persistence. The interface includes tabs for DETECTION, DETAILS, RELATIONS, BEHAVIOR, and COMMUNITY (7). A banner encourages joining the community. Below, it shows a Popular threat label (trojan.msil/jalapeno), Threat categories (trojan, pua), and Family labels (msil, jalapeno, stealer). A table titled 'Security vendors' analysis' lists detections from various vendors.

Security vendors' analysis		Do you want to automate checks?	
AhnLab-V3	Trojan.Win.MalwareX-gen.C5659371	Alibaba	TrojanPSW:MSIL/LummaC.9bb96b68
AliCloud	Trojan[stealer]:MSIL/LummaC.MAY2XJC	ALYac	Gen:Variant.Jalapeno.18063
Arcabit	Trojan.Jalapeno.D468F	Arctic Wolf	Unsafe
Avast	Win32:MalwareX-gen [Pws]	AVG	Win32:MalwareX-gen [Pws]
Avira (no cloud)	HEUR/AGEN.1378432	BitDefender	Gen:Variant.Jalapeno.18063
Bkav Pro	W32.Common.B4360316	ClamAV	Win.Packed.Stelpak.10034590-0
CrowdStrike Falcon	Win/malicious_confidence_100% (W)	CTX	Exe.trojan.msil

Minaccia2: Pagina di "Phishing" (Furto di Credenziali)

Fonte: <https://app.any.run/tasks/f1f20828-2222-46fb-a886-09f77581e67b/>

La seconda analisi ha rivelato un tipo di attacco diverso: il **phishing**. In questo caso, il pericolo non è un software installato sul PC, ma un **sito web fraudolento** che imita perfettamente una pagina legittima (in questo caso, la pagina di login di instagram e Facebook).

L'utente viene indotto con l'inganno a visitare questo sito-trappola. Credendo di essere sul sito reale, inserisce le proprie credenziali (email e password). In quell'istante, i dati vengono **rubati e inviati ai criminali**.

Questa tecnica è pericolosissima perché, molto spesso, le persone riutilizzano le stesse password su più servizi. Con la password di Facebook, un criminale potrebbe tentare di accedere all'email aziendale, a siti di e-commerce o, nei casi peggiori, a servizi bancari.



Dettagli Tecnici dell'Analisi

- **URL Malevolo:** L'indirizzo del sito-truffa è `click.convertab-mail.com`, un dominio che non ha alcuna associazione con Instagram/Meta. L'indicatore principale è il disallineamento tra l'aspetto della pagina e l'URL reale nella barra degli indirizzi.
- **Tecnica di Attacco:** Si tratta di **Social Engineering**, che sfrutta la fiducia dell'utente nel brand "Instagram" e "facebook" per indurlo a compiere un'azione insicura.
- **Mancato Rilevamento Comportamentale:** È importante notare che any.run ha assegnato un punteggio di pericolosità pari a 0/100. Questo **non è un errore**, ma un dettaglio tecnico importante: any.run analizza il comportamento dei processi. Il comportamento di un browser (`chrome.exe`) che visita un sito web è, di per sé, normale e non dannoso. La malevolenza risiede nel contenuto della pagina e nell'intento fraudolento, che richiedono l'analisi umana o sistemi di protezione specifici (come filtri URL) per essere rilevati.



Scelta di Remediation

Analisi: **Vero Negativo** . Il link punta a un sito di phishing

- **Azione Consigliata: Blacklist e Gestione dell'Incidente.**
- **Motivazione:** Non essendoci un file da rimuovere dal computer, l'azione tecnica più efficace è quella preventiva: **inserire** immediatamente in **blacklist** l'indirizzo del sito fraudolento (`click.convertab.ws`) su tutti i sistemi di protezione della rete (firewall, proxy). Questo impedirà a chiunque altro in azienda di poter visitare la pagina. A ciò, deve seguire un'azione interna:
 - 1 - **Verificare** se qualche utente ha inserito le proprie credenziali.
 - 2 - In caso affermativo, imporre un **reset immediato della password** su tutti i servizi potenzialmente coinvolti.
 - 3 - Utilizzare questo caso come esempio per una **comunicazione di sensibilizzazione** a tutto il personale, ricordando di verificare sempre l'URL prima di inserire dati sensibili.